

OpenClaw 路径遍历漏洞（CVE-2026-41370）

一、漏洞概述

- 漏洞名称：OpenClaw 路径遍历漏洞
- CVE ID：CVE-2026-41370
- 漏洞类型：Path Traversal
- 发现时间：2026.4.28
- 漏洞评分：5.3
- 漏洞等级：中等
- 攻击向量：网络
- 所需权限：低
- 利用难度：低
- 用户交互：不需要
- PoC/EXP：未公开

OpenClaw 是一个高性能的跨平台异步通信框架，专门设计用于在复杂的分布式系统和微服务架构中实现高效、低延迟的数据调度与资源管理。它常被开发者用来构建需要大规模并发处理能力的后端服务或自动化平台。

该漏洞源于 OpenClaw 的 ACP 组件在处理进站通道附件路径时存在输入验证不足，导致系统未能对路径序列进行严格规范化校验。当 OpenClaw 处于运行状态且开启了远程附件同步功能时，攻击者可通过操纵附件路径参数，利用 `../` 等遍历序列绕过 Attachment-cache 缓存隔离机制及根目录检查逻辑。由于 ACP 模块在解析路径时优先于沙箱权限校验，攻击者可诱导系统访问预设目录之外的任意文件。利用此漏洞，攻击者可跨越 AI 工作区边界读取服务器及本地主机的敏感配置文件、系统密钥或用户私密数据库，造成严重的信息泄露，并可能为后续获取系统持久化权限提供支撑。

二、影响范围

OpenClaw < 2026.3.31

三、安全措施

3.1 升级版本

官方已发布修复补丁，以修复该漏洞。

OpenClaw >= 2026.3.31

下载链接：<https://github.com/openclaw/openclaw/releases/>

3.2 临时措施

暂无。

3.3 通用建议

- 及时部署组件更新：订阅 OpenClaw 官方安全通告，确保核心框架及配套插件始终处于最新稳定版本，以修复已知路径遍历及权限绕过缺陷。
- 收缩 AI 运行权限：严格遵循最小权限原则，避免以 Root 或 Administrator 权限启动“龙虾”服务。建议将 OpenClaw 部署在独立的容器或低权限沙箱环境中，并限制其对宿主机文件系统的读写范围。

3.4 参考连接

<https://www.cve.org/CVERecord?id=CVE-2026-41370>

<https://ti.qianxin.com/vulnerability/detail/457814>

<https://github.com/openclaw/openclaw/commit/566fb73d9da2d73c0be0d9b8e5b762e4dcd8e81d>